IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Unix and Linux Operating Systems

Part 2

Objectives

- • How to audit Unix and Linux systems, focusing on the following main areas:
- • Account management and password controls
- • File security and controls
- • Network security and controls
- • Audit logs
- • Security monitoring and general controls
- • Tools and resources for enhancing your *nix audits

Test Steps for Auditing *nix

- The following audit steps are divided into five sections:
  • Account management and password controls
- • File security and controls
- • Network security and controls
- • Audit logs
- • Security monitoring and general controls

Test Steps for Auditing *nix

- 1. Review and evaluate procedures for creating Unix or Linux user accounts and ensuring that accounts are created only when there's a legitimate business need. Also, review and evaluate processes for ensuring that accounts are removed or disabled in a timely fashion in the event of termination or job change.
- 2. Ensure that all user IDs in the password file(s) are unique.
  - more /etc/passwd, and review the entries to ensure that there are no duplicate UIDs.
  - The following command will list any duplicate UIDs found in the local password file:
    cat /etc/passwd | awk -F: '{print $3}' | uniq -d

Test Steps for Auditing *nix

- **Awk** is a programming language, allows easy manipulation of data and generation of reports.
- Mostly used for pattern scanning and processing.
- Awk views a text file as records and fields.
- Like common programming language, Awk has variables, conditionals and loops
- Awk has arithmetic and string operators.
- Awk can generate formatted reports.

Test Steps for Auditing *nix

- 3. Ensure that passwords are shadowed and use strong hashes where possible.
  - To determine whether a shadow password file is being used, type **more /etc/ passwd** to view the file.
  - If each account has an "*" or "x" or some other common character in it, the system uses a shadow password file.
  - The shadow password file will be located at /etc/shadow for most systems.
  - MD5 is now the default hash on many Linux systems. The crypt form can be recognized because it is always 13 characters long; an MD5 hash in /etc/passwd or /etc/ shadow will be prepended with the characters 1 and is longer.

Test Steps for Auditing *nix

- 4. Evaluate the file permissions for the password and shadow password files.
  - If a user can alter contents of these files, he will be able to add / delete users, change passwords, or become a superuser by changing his UID to 0.
  - View the file permissions for these files by using the ls –l command on them. The /etc/passwd file should be writable only by "root," and the /etc/shadow file also should be readable only by "root."
- 5. Review and evaluate the strength of system passwords.
  - Password policy is set in /etc/default/passwd. View the PASSLENGTH parameter in this file, to determine minimum password length.

Test Steps for Auditing *nix

- Unfortunately, the standard Unix passwd program does not provide strong capabilities for preventing weak passwords.
- It will prevent a user from choosing his or her username as a password but not much else.
- One stronger possibility is npasswd, a replacement for passwd. Npasswd is currently hosted at www.utexas.edu/cc/unix/software/npasswd/. Additional controls also can be provided through PAM (Pluggable Authentication Modules) by the use of pam_cracklib, pam_passwdqc, or a similar module (pam_cracklib is included in many Linux distributions).

Test Steps for Auditing *nix

- Look for lines beginning with password in /etc/pam.conf or the configuration files in /etc/pam.d/ to get an idea of what's in use on the system you're auditing.
- Perform a more command on these files to view their contents. Consider obtaining a copy of the password file and the shadow password file and executing a password-cracking tool against the encrypted passwords to identify weak passwords.

Test Steps for Auditing *nix

- 6. Evaluate the use of password controls such as aging.
  - Password policy is usually set in /etc/default/passwd. View the MAXWEEKS to determine the maximum age.
- 7. Review the process used by the system administrator(s) for setting initial passwords for new users and communicating those passwords.
  - Accounts can be expired, thus forcing the user to change his or her password on the next login by the use of passwd –f on Solaris and passwd –e on Linux.
  - Ensure that unencrypted transmission of passwords are not used.

Test Steps for Auditing *nix

- 10. Review and evaluate access to superuser (root-level) accounts and other administration accounts.
  - identify all accounts with a UID of 0.
  - Review the password file for the existence of other administration accounts (such as "oracle").
  - If sudo is used, review the /etc/sudoers file to evaluate the ability of users to run commands as "root" (and other sensitive accounts) with the sudo command.
  - The basic format of an entry in the sudoers file would look something like this:
    Andrew ALL=(root) /usr/bin/cat
    Micah ALL=(ALL) ALL
    In this example, user Andrew would be allowed to run the command /usr/bin/cat as the user root on all systems, and user Micah would be allowed to run any command as any user on any system

Test Steps for Auditing *nix

- 11. Review and evaluate the usage of groups and determine the restrictiveness of their usage.
  - Review the contents of /etc/group, /etc/passwd, and related centralized files (NIS) using the more (such as more /etc/passwd) and, for NIS, ypcat (such as ypcat passwd and ypcat group) commands.
  - In other words, if a user is assigned to the "users" group in the /etc/passwd file, there is no need to list him or her as a member of that group in the /etc/group file. Therefore, to obtain a full listing of all members of the "users" group, you must determine who was assigned to that group in the /etc/group file and also determine who was assigned to that group in the /etc/passwd file (along with any NIS, LDAP, and so on, equivalents being used in your environment).

Test Steps for Auditing *nix

- 12. Evaluate usage of passwords at the group level.
  - Group-level passwords allow people to become members of groups with which they are not associated.
  - If a group has a password associated with it in the group file, a user can use the **newgrp <group name>** command and will be prompted to enter that group's password.
  - Once the password is entered correctly, the user will be given the rights and privileges of a member of that group for the session.
  - Creating a group-level password creates another vector of attack on the system by creating the opportunity for users to hack the group-level passwords and escalate their privileges.
  - To look for passwords in /etc/group, you could use this command in your audit script:
    awk -F: '{if($2!="" && $2!="x" && $2!="*")print "A password is set for group "$1" in /etc/group\n"}' /etc/group

Test Steps for Auditing *nix

- 13. Review and evaluate the security of directories in the default path used by the system administrator when adding new users. Evaluate the usage of the "current directory" in the path.
  - Difference between /bin/ls /home & ls /home ?
  - For example, let's say that your path looks like this: /usr/bin:/usr/local/bin:/bin What does this means?
  - If the permissions on that file grant you execute permissions, you will be allowed to run the program.
  - The easiest way to view your own path is by typing echo $PATH at the command line.
  - The default setting for users' paths may be found in /etc/default/login, /etc/profile, or one of the files in /etc/skel.

Test Steps for Auditing *nix

- 14. Review and evaluate the security of directories in root's path. Evaluate the usage of the "current directory" in the path.
  - review the permissions of each directory using the ls -ld command.
  - The following will print the permissions of root's path (assuming that the script is executed as root) and warn if there is a "." in the path or if one of the directories is world writable:

```
#!/bin/sh
for i in `echo $PATH | sed 's/:/ /g'`
do
if [ "$i" = . ]
then
echo -e "WARNING: PATH contains .\n"
else
ls -ld $i
ls -ld $i | awk '{if(substr($1,9,1)=="w")print "\nWARNING -
" $i " in root'\''s' path is world writable"}'
fi
done
```